Production Readiness Criteria

AWS RDS Operational Validation Framework for Sterling Checkout

1. Purpose & Scope

This validation framework establishes the rigorous operational checkpoints, performance gates, and security verifications required to certify the AWS RDS infrastructure layer for Sterling Checkout as production-ready. Successful sign-off across all verification gates is an absolute prerequisite before opening the cluster to live global merchant transaction traffic.

2. Network Isolation & Routing Gates

Verification must confirm complete network containment within the isolated corporate application VPC infrastructure.

Gate ID / Target	Verification Protocol & Expected Metric
NET-01 Public Separation	Execute network route tracing. Assert that the RDS cluster has **PubliclyAccessible = false**. Verify there are zero direct public routes or internet gateway targets mapped in database subnet route tables.
NET-02 Subnet Alignment	Audit the database subnet group configuration. Confirm active bindings are strictly limited to private subnets **10.0.1.0/24** (AZ A) and **10.0.2.0/24** (AZ B) within the **10.0.0.0/16** VPC boundary.

3. Cryptographic & Ingress Security Attestation

Data security configurations must conform exactly to industry payment processing security criteria through automated policy checks.

Gate ID / Target	Verification Protocol & Expected Metric
SEC-01 At-Rest Cryptography	Query the AWS RDS metadata layer to confirm **StorageEncrypted = true** and verify the binding of an active, customer-managed AWS KMS key using the AES-256 cipher standard.
SEC-02 In-Transit Enforcement	Verify parameter group settings. Assert that **rds.force_ssl = 1** is configured. Attempt a connection unencrypted via plain text port mapping; the database must instantly discard and drop the connection.
SEC-03 Ingress Containment	Audit security group rules on ingress port 5432. Confirm access vectors are restricted exclusively to defined private security groups corresponding to the **Checkout**, **Order**, **Payment**, and **Reporting** microservices.

4. Performance & Scale Benchmarking

Database instances must undergo comprehensive load testing simulating maximum transaction spikes under synthetic production loads.

• **Throughput Capacity:** Validate the cluster's ability to maintain high Transactions Per Second (TPS) volumes under simulated peak checkout stresses without connection starvation or engine saturation.

• **Latency Metrics:** Assert that execution latency for standard order ingestion and transactional writes remains firmly below the **15ms** threshold to guarantee frictionless client UX.

• **Elastic Storage Auto-scaling:** Simulate write-heavy data logging blocks to trigger automated volume expansion. Verify that AWS RDS storage auto-scaling triggers flawlessly without downtime or degradation.

5. Disaster Recovery & Operational Resilience

Resilience checkpoints guarantee data safety and recovery velocities aligned with platform-wide availability SLAs.

• **Simulated AZ Failover (RTO/RPO):** Trigger a manual synthetic crash of the primary instance in AZ A. Automated metrics must confirm synchronous failover promotion of the AZ B replica in **< 60 seconds** with **Zero Data Loss (RPO = 0)**.

• **Point-In-Time Recovery (PITR):** Confirm the automated backup retention configuration is set to a minimum of 7 days (target 35 days). Execute a mock recovery task from a transaction log snapshot to verify block consistency.

• **Monitoring & Guardrails:** Verify that Amazon CloudWatch alarms are fully bound and monitoring key metrics: CPU Utilization (>70% threshold), Free Storage Space, Memory saturation, and IOPS throttling queues.

6. Administrative Access Governance Audit

Management channels are audited to guarantee airtight separation between operators and live transaction spaces.

• **Bastion Containment:** Verify that all administrative connectivity to the database instance routes exclusively through the secure AWS Bastion Host. Confirm direct external routing to the database cluster is structurally impossible.

• **Authentication Rules:** Assert that Bastion Host access requires active Multi-Factor Authentication (MFA).

• **JIT & Accountability:** Verify that admin access utilizes Just-In-Time (JIT) time-bounded credentials, and all operations generate immutable, centrally consolidated logs within security monitoring buckets.